

WILMS

Women's Interest-Free Loan Management System

API Reference — v1.7.3

WILMS API Reference

Version: 1.7.3 Base URL: /api/wilms (in-process) or /api/v1 (standalone domain) Auth: HMAC session cookie (wilms_session) Classification: Confidential

1. Overview

WILMS exposes a REST JSON API via @wilms/domain Express routers mounted through Next.js Route Handlers. All authenticated endpoints require a valid HMAC session cookie unless noted as public.

Response envelope

```
{ "data": { ... }, "meta": { "requestId": "..." } }
```

Error envelope

```
{ "error": { "code": "VALIDATION", "message": "Human-readable message" } }
```

Common codes: UNAUTHORIZED (401), FORBIDDEN (403), NOT_FOUND (404), VALIDATION (422).

2. Authentication (/auth)

Method	Path	Auth	Description
--------	------	------	-------------

-----	-----	-----	-----
-------	-------	-------	-------

POST	/auth/login	Public	Email/password login; sets session cookie
------	-------------	--------	---

POST	/auth/logout	Session	Clear session
------	--------------	---------	---------------

GET	/auth/me	Session	Current user profile
-----	----------	---------	----------------------

POST	/auth/otp/verify	Public	Verify login OTP challenge
------	------------------	--------	----------------------------

POST	/auth/password-reset/request	Public	Request reset email
------	------------------------------	--------	---------------------

POST	/auth/password-reset/confirm	Public	Reset with token
------	------------------------------	--------	------------------

POST	/auth/onboarding/complete	Session	Complete first-login onboarding
------	---------------------------	---------	---------------------------------

Sessions are HMAC-signed cookies — not JWT bearer tokens, not Auth.js.

3. Borrowers (/borrowers)

Method	Path	Permission	Description
--------	------	------------	-------------

-----	-----	-----	-----
-------	-------	-------	-------

| GET | /borrowers | REGISTER/VIEW | List borrowers (paginated, filtered) |

| POST | /borrowers | REGISTER_BORROWERS | Create borrower |

| GET | /borrowers/:id | VIEW | Borrower profile |

| PATCH | /borrowers/:id | EDIT_BORROWERS | Update borrower |

| GET | /borrowers/pending | REGISTER | Pending registrations |

4. Loans (/loans)

| Method | Path | Permission | Description |

|-----|-----|-----|-----|

| GET | /loans | VIEW | List loans |

| POST | /loans | REGISTER | Create loan application |

| GET | /loans/:id | VIEW | Loan detail with schedule |

| POST | /loans/:id/approve | APPROVE_LOANS | Approve loan |

| POST | /loans/:id/reject | REJECT_LOANS | Reject loan |

| POST | /loans/:id/disburse | ADMIN | Disburse approved loan |

Disbursement hard-stops if pool insufficient or admin fee unpaid.

5. Loan pools (/loan-pools)

| Method | Path | Permission | Description |

|-----|-----|-----|-----|

| GET | /loan-pools | ADMIN | List pools |

| POST | /loan-pools | ADMIN | Create pool |

| GET | /loan-pools/:id | ADMIN | Pool detail with ledger |

| POST | /loan-pools/:id/replenish | ADMIN | Add capital |

| GET | /loan-pools/:id/transactions | ADMIN | Ledger entries |

6. Payments (/payments)

| Method | Path | Permission | Description |

|-----|-----|-----|-----|

| GET | /payments | VIEW | List payments |

| POST | /payments | RECORD_COLLECTIONS | Record collection |

| GET | /payments/:id | VIEW | Payment detail |

| POST | /payments/:id/reverse | ADMIN | Reverse payment |

Collections require full weekly amount. GPS metadata attached on field capture.

7. Reconciliation (/reconciliation)

| Method | Path | Permission | Description |

|-----|-----|-----|-----|

| GET | /reconciliation | VIEW | List reconciliations |

| POST | /reconciliation | RECORD_COLLECTIONS | Submit daily reconciliation |

| GET | /reconciliation/:id | VIEW | Reconciliation detail |

| POST | /reconciliation/:id/approve | ADMIN | Approve reconciliation |

8. Expenses (/expenses)

| Method | Path | Permission | Description |

|-----|-----|-----|-----|

| GET | /expenses | VIEW | List expenses |

| POST | /expenses | RECORD_EXPENSES | Submit expense |

| POST | /expenses/:id/approve | ADMIN | Approve expense |

| POST | /expenses/:id/reject | ADMIN | Reject expense |

Maker-checker: submitter cannot approve own expense.

9. Intelligence (/intelligence, /exports)

| Method | Path | Permission | Description |

|-----|-----|-----|-----|

| GET | /intelligence/executive-dashboard | ADMIN/VIEW_REPORTS | Executive KPIs |

| GET | /intelligence/forecast | VIEW_FINANCIAL | Forecast snapshot |

| GET | /intelligence/portfolio-breakdown | VIEW_REPORTS | Portfolio dimensions |

| GET | /intelligence/compliance-pack | EXPORT_REPORTS | Compliance data |

| GET | /exports/jobs | EXPORT_REPORTS | List export jobs |

| POST | /exports/jobs | EXPORT_REPORTS | Create export job |

| GET | /exports/jobs/:id | EXPORT_REPORTS | Job status |

| DELETE | /exports/jobs/:id | EXPORT_REPORTS | Delete job |

| POST | /exports/jobs/:id/regenerate | EXPORT_REPORTS | Regenerate job |

10. Notifications (/notifications)

Method	Path	Permission	Description
GET	/notifications	Session	List user notifications
PATCH	/notifications/:id/read	Session	Mark read
POST	/notifications/read-all	Session	Mark all read

11. Communications (/communications, /messages)

Method	Path	Permission	Description
GET	/communications/templates	ADMIN	List templates
POST	/communications/broadcasts	ADMIN	Send broadcast
GET	/messages	Session	Message threads
POST	/messages	Session	Send message

12. Operations (/ops)

Method	Path	Permission	Description
GET	/ops/incidents	ADMIN	List incidents
POST	/ops/incidents	ADMIN	Create incident
GET	/ops/maintenance	ADMIN	Maintenance windows
POST	/ops/maintenance	ADMIN	Schedule maintenance

Soft-fail reads when migration tables not yet applied.

13. Reports (/reports)

Method	Path	Permission	Description
GET	/reports/:type	VIEW_REPORTS	Generate report
GET	/reports/:type/summary	VIEW_REPORTS	Summary aggregates

Oversized unpaginated requests return 422.

14. Audit (/audit)

Method	Path	Permission	Description
--------	------	------------	-------------

-----	-----	-----	-----
-------	-------	-------	-------

GET	/audit	VIEW_AUDIT_LOG	Query audit log
-----	--------	----------------	-----------------

Append-only. No delete endpoint.

15. Settings (/settings)

Method	Path	Permission	Description
--------	------	------------	-------------

-----	-----	-----	-----
-------	-------	-------	-------

GET	/settings	ADMIN	Organisation settings
-----	-----------	-------	-----------------------

PATCH	/settings	ADMIN	Update settings
-------	-----------	-------	-----------------

GET	/settings/users	MANAGE_USERS	List users
-----	-----------------	--------------	------------

POST	/settings/users/invite	MANAGE_USERS	Invite user
------	------------------------	--------------	-------------

16. Additional modules

Module	Base paths	Notes
--------	------------	-------

-----	-----	-----
-------	-------	-------

Groups	/groups	Group CRUD and members
--------	---------	------------------------

Collectors	/collectors	Collector management
------------	-------------	----------------------

Collector portal	/collector-portal	Field-specific endpoints
------------------	-------------------	--------------------------

Dashboard	/dashboard	Dashboard aggregates
-----------	------------	----------------------

Risk flags	/risk-flags	Risk indicator CRUD
------------	-------------	---------------------

Adjustments	/adjustments	Pool adjustments
-------------	--------------	------------------

Analytics	/analytics	Analytics events
-----------	------------	------------------

Search	/search	Global search
--------	---------	---------------

Sync	/sync	Offline queue replay
------	-------	----------------------

Uploads	/uploads	File upload with allowlist
---------	----------	----------------------------

Locations	/locations	Ghana location hierarchy
-----------	------------	--------------------------

Photo capture	/photo-capture	Public mobile capture
---------------	----------------	-----------------------

Health	/health	Public health check
--------	---------	---------------------

Webhooks	/webhooks	External webhook receivers
----------	-----------	----------------------------

17. Rate limiting

Global: 300 requests/minute per IP. Login endpoints have additional rate limiters. Returns 429 when exceeded.

18. CSRF

Mutating requests through BFF paths require CSRF token. Session cookie alone insufficient for state-changing frontend form posts.

CONFIDENTIAL — For authorized WILMS personnel, executive review, procurement, and official record keeping only.